

Forma **TEC**

CLASE 2

Encriptación y cumplimiento



Previamente

Recordemos

Comentarios o dudas sobre la última clase:

- Seguridad: IAM

Fundamentos

Introducción

Criptografía Aplicada y Cumplimiento en la Nube

De las matemáticas del cifrado
a la física del hardware y la
certificación ISO 27017.

Fundamentos

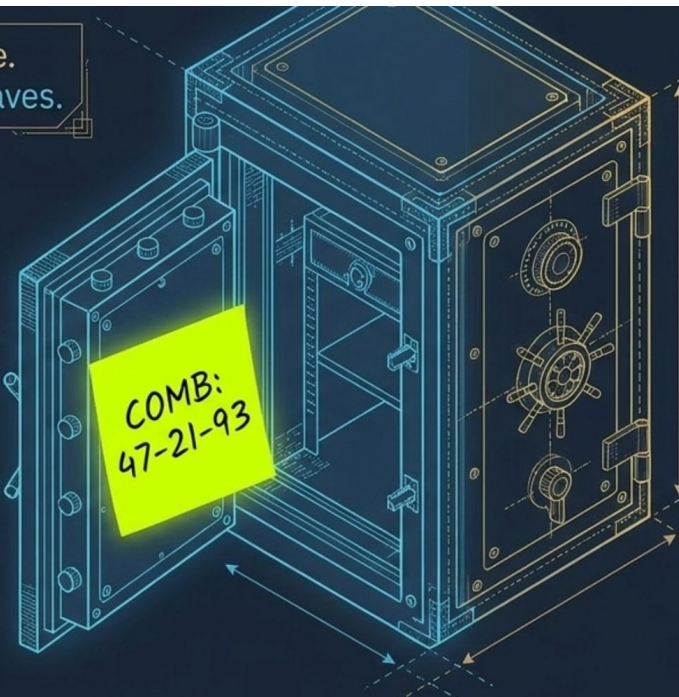
La paradoja de la caja fuerte

El cifrado convierte texto legible en texto ilegible.
Pero el cifrado es matemática muerta sin sus claves.

La vulnerabilidad principal:
El cifrado es exactamente tan seguro como la gestión de sus claves criptográficas.

Pérdida: Si se pierde la clave, los datos quedan permanentemente inaccesibles.

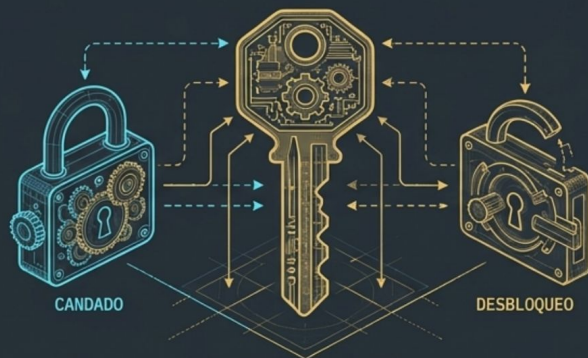
Robo: Si se roba la clave o se gestiona mal, la caja fuerte está abierta, anulando toda la inversión en algoritmos.



Fundamentos

Tipos de cifrado

Cifrado Simétrico



Mecanismo: Una única clave compartida para cifrar y descifrar (ej. AES).

Reto Operativo: Generación, almacenamiento y distribución extrema; si la clave se compromete, todo el set de datos cae.

Cifrado Asimétrico



Mecanismo: Un par matemático. Clave pública (abierta) para cifrar; clave privada (secreta) para descifrar.

Aplicación: Infraestructura de Clave Pública (PKI), firmas digitales, autenticación e intercambio seguro.

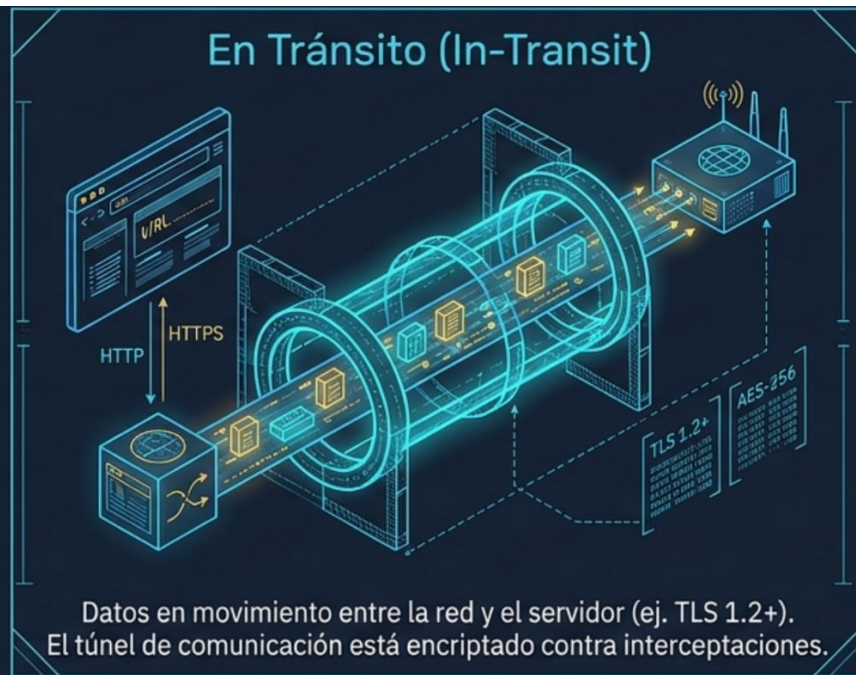
Fundamentos

Ciclo de vida de la clave



Fundamentos

Importancia de la gestión de claves



Fundamentos

Metodo de gestion KMS



Estrategia de Rotación: Rotar la CMK periódicamente limita el radio de explosión sin necesidad de re-encryptar petabytes de datos en reposo.

Fundamentos

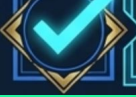
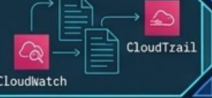
Normas y cumplimientos

La tecnología proporciona las herramientas; las normativas proporcionan el lenguaje para demostrar la seguridad a terceros.

ISO 27001	Gestión de Seguridad de la Información (El estándar general y fundacional).
ISO 27017 (Nuestro Foco)	Controles de seguridad específicos para servicios Cloud.
ISO 27018	Protección específica de datos personales (PII) en la nube pública.
GDPR	Reglamento europeo de protección de datos (Obligatorio a nivel legal).

Fundamentos

El checklist ISO

	 1. Gobernanza: ¿Está el SLA de brechas documentado? ¿Hay derecho a auditoría SOC 2? 
	 2. Activos: ¿Conocemos la localización geográfica exacta? (Crucial para GDPR). 
	 3. Accesos (IAM): ¿Existe MFA obligatorio y procesos de segregación de entornos (Prod vs Dev)? 
	 4. Criptografía: ¿Usa TLS 1.2+ en tránsito? ¿Rota KMS anualmente? ¿Están los discos EBS y S3 encriptados? 
	 5. Operaciones: ¿Están los logs (CloudWatch/CloudTrail) activos y guardados en almacenamiento inmutable? 

Fundamentos

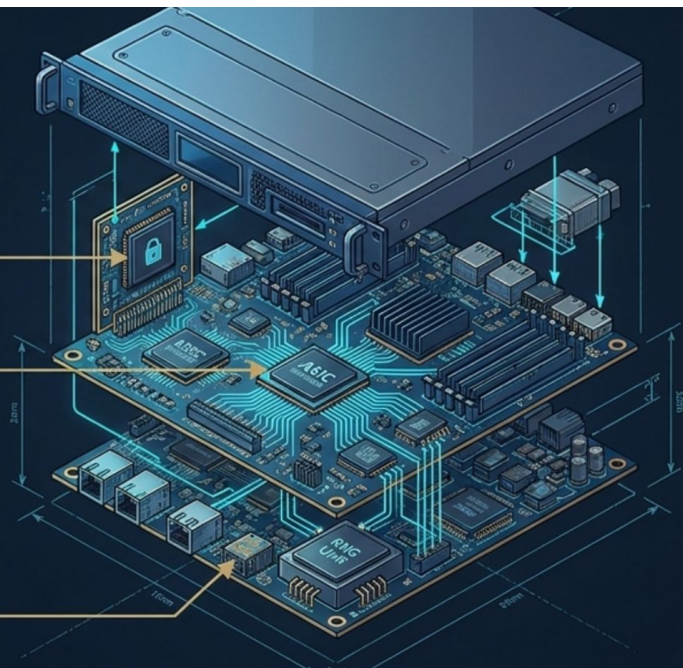
HW Security Modules (HSM)

Dispositivos físicos o aparatos de red dedicados exclusivamente a **generar, almacenar y procesar** claves sensibles.

Aislamiento Absoluto: Las claves se generan internamente sin dejar rastro en el sistema de archivos del servidor.

Offloading Criptográfico: ASICs integrados asumen la inmensa carga computacional (ej. firmar 10,000 documentos por hora), liberando la RAM y CPU.

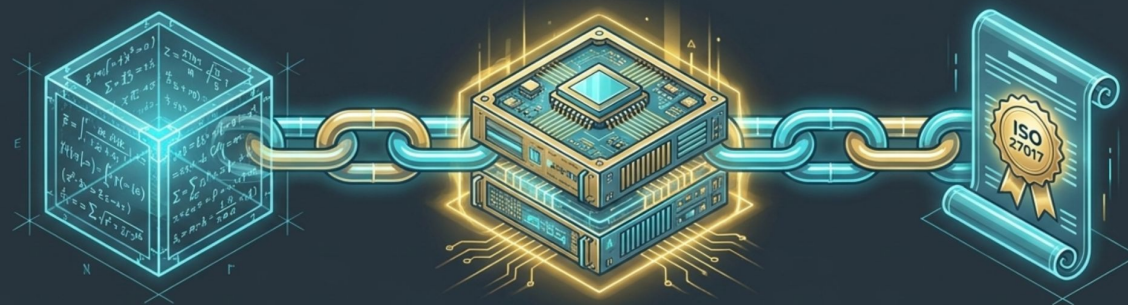
Calidad de Entropía: Generadores de Números Aleatorios (RNG) de hardware puro.



Cierre

Preguntas o Dudas

Síntesis: La Cadena Inquebrantable



1. Las Matemáticas: El cifrado es la base teórica.

2. La Física: El HSM y KMS aseguran que la matemática no pueda ser físicamente manipulada.

3. La Ley: La ISO 27017 audita y legitima todo el sistema ante el mundo.

Una verdadera postura de ciberseguridad requiere el dominio perfecto de estas tres dimensiones. **El cifrado sin gestión de hardware es inútil; la gestión sin cumplimiento normativo es invisible.**

Próximos pasos

Manos a la obra

Herramientas o apps

- Cuenta en nube (AWS, Azure, GCP o similar)
- Acceso administrador a dicha cuenta